Premesse e note legali

- Le attività di laboratorio e le simulazioni di hacking etico descritte in questo documento sono state condotte utilizzando il software *Metasploit* (e/o altri strumenti di *penetration testing*) esclusivamente per finalità educative, didattiche e di studio.
- Ogni test di vulnerabilità ed exploit è stato eseguito all'interno di un ambiente di laboratorio isolato, controllato e preventivamente autorizzato, senza impattare in alcun modo sistemi di produzione o reti terze.
- Il relatore ricorda che l'accesso non autorizzato a sistemi informatici o telematici, così come il danneggiamento di dati e programmi, costituisce un reato punibile penalmente ai sensi delle leggi vigenti. L'autore declina ogni responsabilità per l'uso improprio o illecito delle informazioni e delle tecniche qui illustrate.

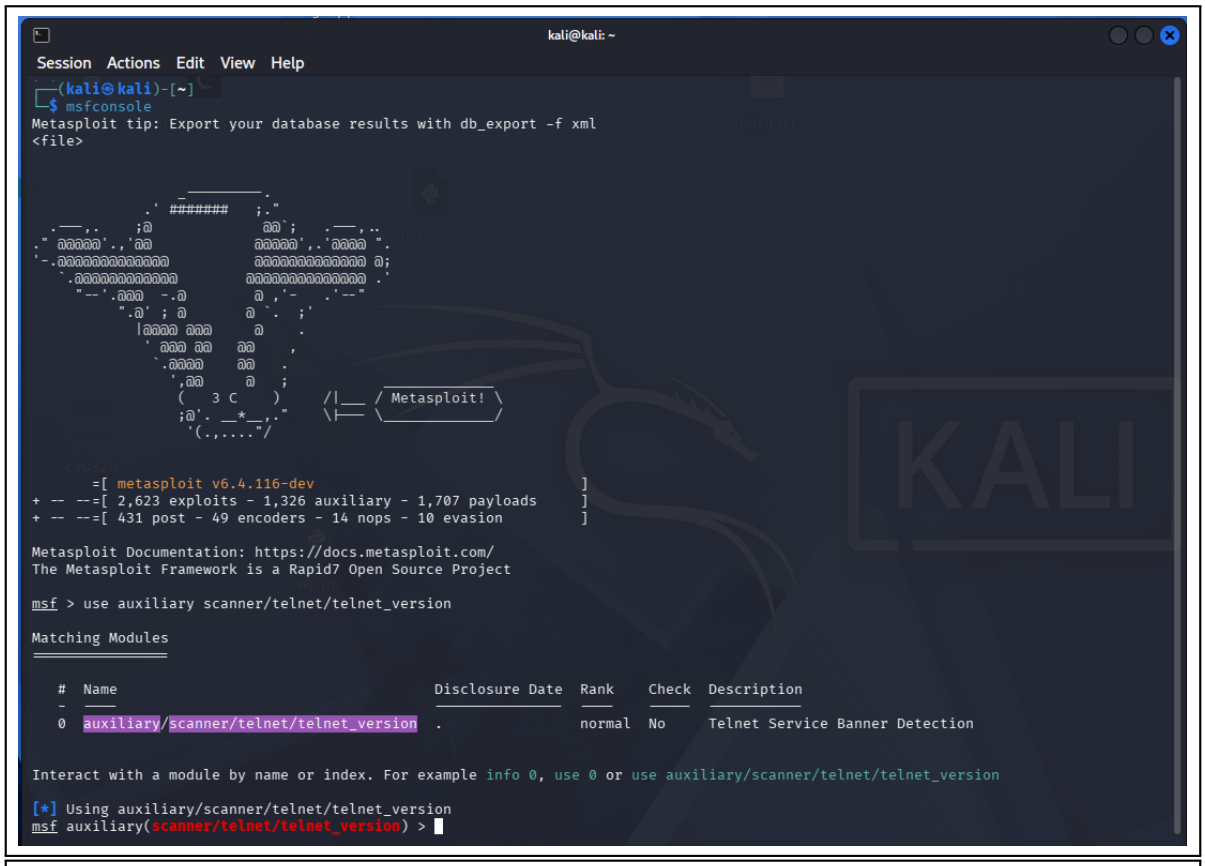
1 Ambiente operativo

Le attività descritte nel presente report sono state eseguite all'interno di un ambiente di laboratorio virtualizzato tramite l'hypervisor Oracle VirtualBox. La topologia di rete prevede due macchine virtuali attestate sulla medesima sottorete:

- Macchina vituale *Kali Linux*, come macchina attaccante, con indirizzo IP imposto a `192.168.11.111`
- Macchina vituale *Metasploitable*, come macchina vittima, con indirizzo IP imposto a `192.168.11.112`

Lo sfruttamento della vulnerabilità legata al servizio Java RMI è stato condotto utilizzando il framework *Metasploit* tramite l'interfaccia a riga di comando `msfconsole`.

2 Evidenze fotografiche delle attività



Schermata della linea di comando con il software `msfconsole` con indicazione di uso del modulo `auxiliary scanner/telnet/telnet_version`

```
msf auxiliary(scanner/telnet/telnet_version) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf auxiliary(scanner/telnet/telnet_version) >
```

Schermata dell'output del comando di impostazione del parametro `RHOST` della linea di comando del software `msfconsole`

```
msf auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   PASSWORD                   no        The password for the specified username
   RHOSTS    192.168.50.101   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-met
                                        asploit.html
   RPORT     23               yes       The target port (TCP)
   THREADS   1                yes       The number of concurrent threads (max one per host)
   TIMEOUT   30               yes       Timeout for the Telnet probe
   USERNAME                   no        The username to authenticate as


View the full module info with the info, or info -d command.

msf auxiliary(scanner/telnet/telnet_version) >
```

Schermata dell'output del comando show options della linea di comando del software `msfconsole`

```
msf auxiliary(scanner/telnet/telnet_version) > exploit
[+] 192.168.50.101:23     - 192.168.50.101:23 TELNET _                                                   _ _      _ _      _      _      ____  \x0a _ __ ___   ___| |
_ __ ___ _ __ | | ___ (_) |_ __ _| |__ | | ___|___ \ \x0a| '_ ` _ \ / _ \ __/ _` / __| '_ \| |/ _ \| | __/ _` | '_ \| |/ _ \ __) |
\x0a| | | | |  __/ || (_| \__ \ |_) | | (_) | | || (_| | |_) | |  __// __/ \x0a|_| |_| |_|\___|\__\__,_|___/ .__/|_|\___/|_|\__\__
,__|_.__/|_|\___|_____|\x0a                                |_|                                                \x0a\x0a\x0aWarning: Never expose
 this VM to an untrusted network!\x0a\x0aContact: msfdev[at]metasploit.com\x0a\x0aLogin with msfadmin/msfadmin to get started\x0a\x0
a\x0ametasploitable login:
[*] 192.168.50.101:23     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_version) >
```

Schermata dell'output del comando *exploit* della linea di comando del software `msfconsole`